SIMATS ENGINEERING
ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking **COURSE CODE: ITA14**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain **tesla.com** using **theHarvester** in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. **(20 Marks)**

2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks**.(20 Mark).**

3. Using **Nmap Aggressive Scan (-A)** on **scanme.nmap.org**, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.**(10 Marks)**

Code of Conduct:

I Ch. Tharunika Reddy(192324307) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: Ch. Tharunika Reddy

RUBRICS FOR CALCULATION

Social Engineering Simulation

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Social Engineering Scenario	20%	Demonstrates a comprehensive understanding of the social engineering scenario, attack techniques, and security context	Demonstrates good understanding with minor omissions.	Shows partial understanding but misses important aspects of the scenario.	Fails to understand or incorrectly interprets the social engineering scenario.
Identification of Attack and Vulnerabilities	20%	Correctly identifies the attack type, exploited vulnerabilities, and affected assets with complete accuracy	Correctly identifies most attack techniques with minor errors.	Identifies only some attack methods and vulnerabilities.	Unable to identify the attack type or associated vulnerabilities.
Application of Security Concepts and Countermeasures	25%	Effectively applies cybersecurity concepts and recommends appropriate preventive, detective, and corrective countermeasures.	Applies relevant concepts with minor errors and recommends suitable countermeasures.	Applies concepts partially with limited recommendations.	Unable to apply relevant cybersecurity concepts or recommend suitable countermeasures.
Risk Analysis and Decision Making	20%	Performs logical risk analysis, evaluates business impact, and provides well-justified security decisions.	Provides reasonable analysis with adequate justification.	Performs limited analysis with weak justification.	Provides no meaningful analysis or justification.
Clarity, Documentation and Technical Presentation	15%	Response is well-organized, technically accurate, professionally documented, and logically presented.	Response is clear with minor documentation or presentation issues.	Response lacks organization and contains technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

Question 1 – OSINT-Based Email Enumeration Using the Harvester

1. Introduction

Open-Source Intelligence (OSINT) is the process of collecting and analyzing publicly available information about an organization, its employees, infrastructure, and online presence. In ethical hacking, OSINT helps security analysts understand what information an organization unintentionally exposes to the public.TheHarvester is a reconnaissance tool available in Kali Linux that collects information from supported public sources. Depending on the source and configuration, it may identify email addresses, subdomains, hostnames, and IP addresses associated with a target domain.

In this assessment, `tesla.com` is the target domain specified in the question. The assessment aims to understand how publicly available information could create social engineering risks and how the organization could reduce unnecessary information exposure.Scope and authorization: Perform the assessment only within the permitted scope of your assignment. Collect public information, avoid accessing accounts or restricted systems, and do not send phishing messages or attempt credential collection as part of this OSINT task.

2. Objectives

The main objectives are:

1. Identify publicly discoverable email addresses associated with the target domain.
2. Discover subdomains and hostnames available through permitted public sources.
3. Examine IP address information returned by the tool.
4. Categorize email addresses by likely organizational role when sufficient evidence is available.
5. Analyze the potential impact of information exposure on social engineering.
6. Recommend practical controls to reduce reconnaissance and phishing risks.

3. Tools and Technologies Required

Tool	Purpose
Kali Linux	Security testing environment
theHarvester	Public email and domain reconnaissance
Terminal	Execute commands and record results
DNS utilities	Validate relevant DNS information
Text editor or spreadsheet	Organize and document findings

4. Procedure and Commands

Step 1: Open Kali Linux

Start Kali Linux in your authorized lab environment. Open a terminal and verify that theHarvester is installed.

```
theHarvester -h
```

This command displays the available options and usage information.If the tool is not installed, use the package manager appropriate for your Kali Linux version and follow its official installation guidance.

Step 2: Identify supported data sources

TheHarvester supports different search engines and public data sources depending on the installed version and available integrations.Check the help output to identify supported sources. Choose an appropriate public source supported by your installation.

Step 3: Perform domain reconnaissance

An illustrative command is:

```
theHarvester -d tesla.com -b crtsh
```

Here:

- `theHarvester` launches the reconnaissance tool.
- `-d tesla.com` specifies the target domain.
- `-b crtsh` selects the certificate-transparency source, if supported by the installed version.

Certificate-transparency records may reveal domain names associated with publicly issued TLS certificates. This example does not guarantee that email addresses or IP addresses will be returned.For email enumeration, choose a supported source that actually provides email information. Options and availability can change between versions, so check `theHarvester -h` before selecting the source.

Step 4: Save the assessment output

Record the terminal output and any available results in your lab report. If your installed version supports output export, consult its help output for the correct export option.

Document:

- Date and time of assessment.
- Target domain.
- Selected data source.
- Command executed.
- Number of records returned.
- Limitations or errors encountered.

Step 5: Validate the results

Review discovered domains and hostnames for relevance to the target domain. Distinguish verified records from possible false positives, stale information, and third-party infrastructure.

Do not assume that every discovered subdomain belongs to a system directly controlled by the organization. Hosting providers, content delivery networks, and external service providers may also appear in results.

5. Categorization of Discovered Email Addresses

Email addresses should be categorized based on their names, public descriptions, and other available evidence. The following table provides examples of possible role categories; these are illustrative examples, not verified email addresses or actual findings from Tesla.

Category	Illustrative pattern	Potential information exposed
Support	`support@domain.com`	Customer support processes
Sales	`sales@domain.com`	Sales and business inquiries
Human Resources	`careers@domain.com`	Recruitment and hiring processes
Administration	`admin@domain.com`	Administrative functions
Technical Teams	`it@domain.com`, `security@domain.com`	Technical support and security contacts

A role should not be assigned based on an address alone if the evidence is ambiguous. Record the source of each finding and avoid including personal employee information that is unnecessary for the assessment.

6. Analysis of Reconnaissance Findings

A. Email address exposure

Public email addresses may help attackers identify organizational departments and construct convincing messages. For example, a publicly listed support address could be impersonated in a fraudulent customer-service message.

B. Subdomain discovery

Subdomains may reveal services such as documentation portals, development environments, recruitment websites, or customer-facing applications.An attacker could use this information to understand the organization's online footprint. However, a discovered subdomain is not automatically vulnerable, and ownership or operational status should be verified before drawing conclusions.

C. Hostname and IP address exposure

Hostnames and IP addresses may provide information about the organization's infrastructure. Analysts should distinguish public-facing systems from internal names and third-party hosting infrastructure.The presence of an IP address does not prove that the associated system is directly controlled by the target organization or that it is vulnerable.

D. Organizational information exposure

Public job postings, staff directories, press releases, and technical documentation can reveal department names, technology choices, and business relationships. When combined, these details may make social engineering attempts more convincing.

7. How Attackers Could Misuse OSINT Findings

A. Spear-phishing

Spear-phishing is a targeted phishing attack designed for a particular person, department, or organization.

An attacker might use a publicly identified department name and knowledge of an organization's business processes to create a message that appears relevant to the recipient. The goal may be to persuade the recipient to open a malicious link, disclose information, or perform an unauthorized action.

B. Credential harvesting

Attackers may attempt to trick users into entering their passwords on fraudulent login pages. Publicly exposed email addresses can help identify potential recipients, while information about the organization's services may make fraudulent messages appear more credible.

C. Impersonation attacks

Attackers may impersonate IT support, human resources, management, or external service providers. They may use public organizational information to make false requests appear legitimate.

D. Business email compromise

Information about employee roles and business relationships may help attackers create fraudulent payment requests or messages involving invoices, payroll, and confidential documents.These are potential attack scenarios, not evidence that any such attack has occurred against the target.

8. Risk Analysis

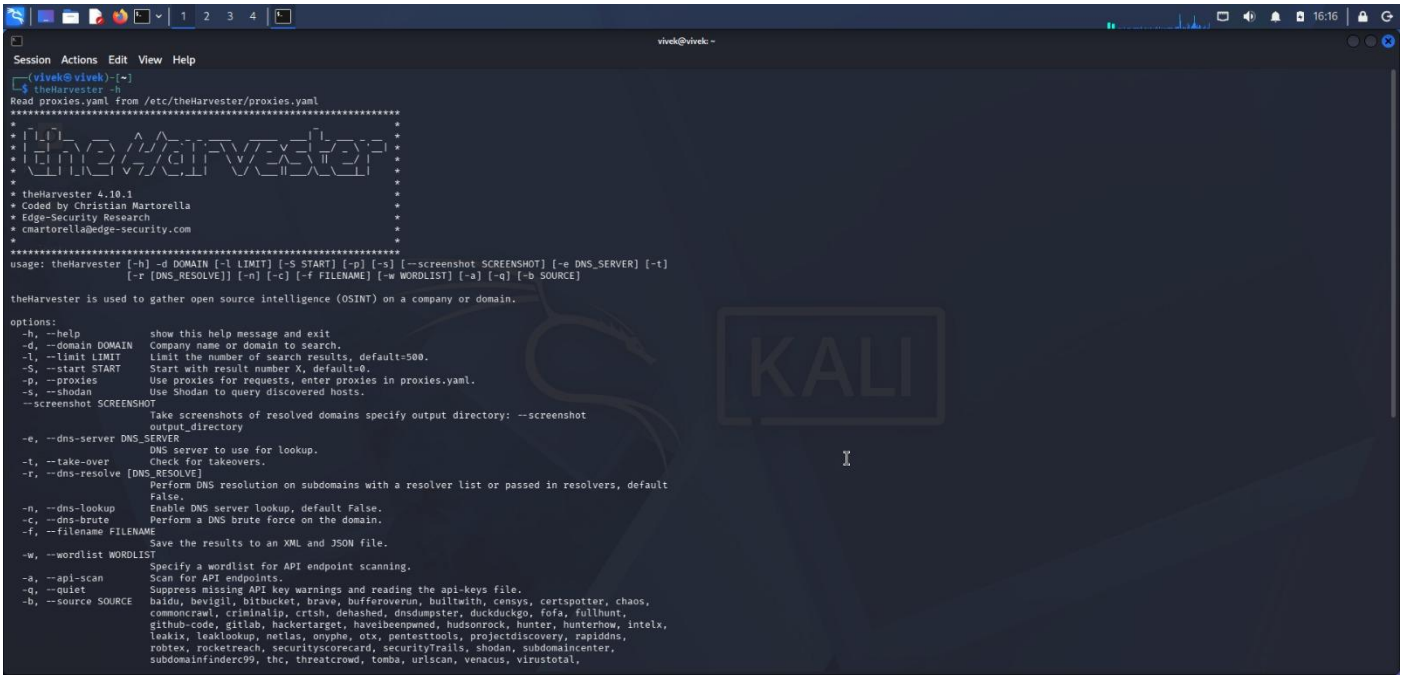
Finding	Risk level	Possible impact
Public departmental email addresses	Low to medium	Targeted phishing attempts
Numerous exposed subdomains	Medium, depending on sensitivity	Expanded reconnaissance opportunities
Information about technical infrastructure	Medium, depending on detail	More targeted vulnerability research
Sensitive internal information exposed publicly	High, if confirmed	Increased risk of targeted attacks and data exposure

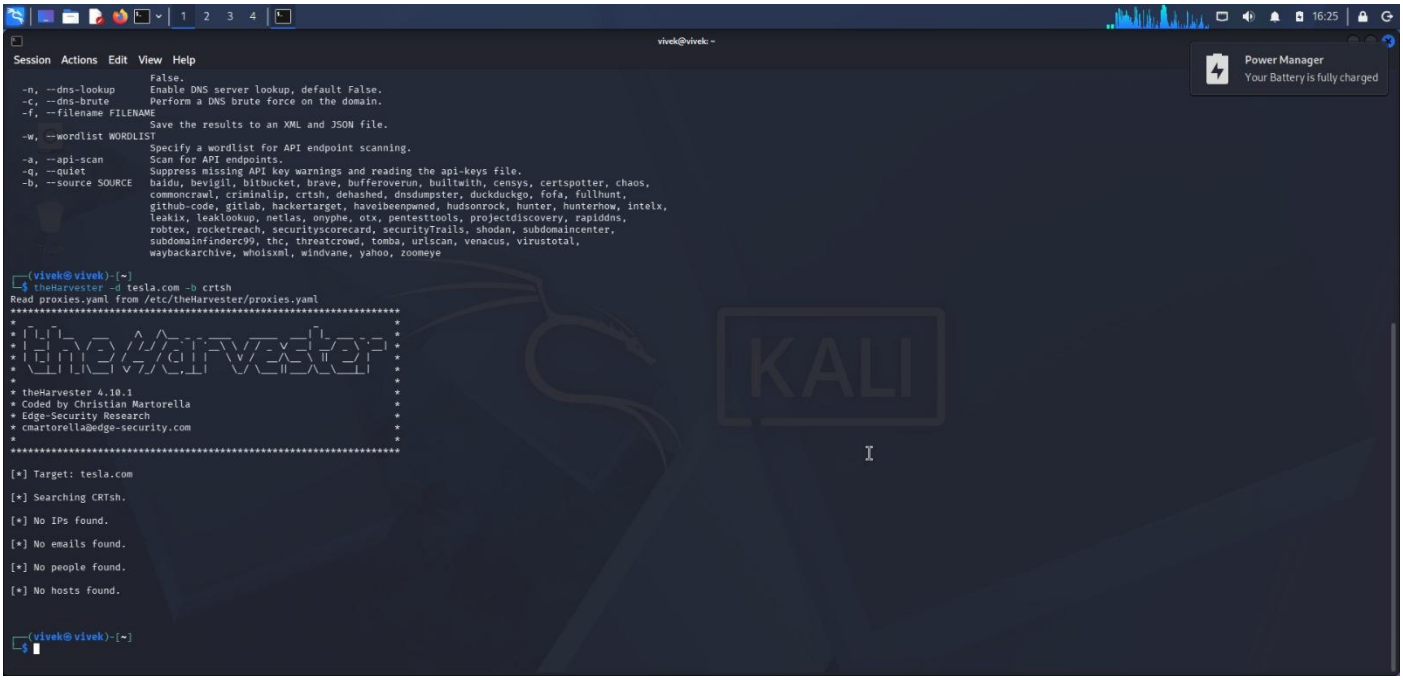
Risk levels should be finalized after validating the findings, determining whether the information is genuinely sensitive, and considering existing security controls.

9. Countermeasures and Recommendations

1. Minimize unnecessary information exposure: Review public websites, staff directories, documentation, and repositories for sensitive information that does not need to be public.
2. Strengthen email authentication: Configure SPF, DKIM, and DMARC to help reduce domain spoofing.
3. Enable multifactor authentication: Use MFA, preferably phishing-resistant authentication, for important organizational accounts.
4. Conduct regular OSINT assessments: Review publicly available information periodically and remediate unintended disclosures.
5. Provide security awareness training: Teach employees to identify suspicious requests, verify sender identities, and report phishing attempts.
6. Secure public-facing services: Maintain an inventory of subdomains and internet-facing systems, remove unused assets, and patch vulnerable software.
7. Apply least privilege: Limit access to confidential systems and information according to job responsibilities.
8. Monitor for impersonation: Watch for suspicious lookalike domains and fraudulent messages that misuse the organization's identity.
9. Protect employee information: Publish only the contact details necessary for business operations.
10. Maintain an incident response process: Establish procedures for investigating phishing reports, compromised accounts, and accidental data disclosure.

10. Screenshots and Evidence to Include





11. Conclusion

OSINT-based email enumeration helps security analysts understand how publicly available information may expose organizational contacts and infrastructure details. TheHarvester can assist in collecting emails, subdomains, hostnames, and related information from supported sources. These findings may help an attacker prepare spear-phishing, credential-harvesting, and impersonation attempts. Organizations can reduce these risks through information-exposure reviews, email authentication, MFA, employee training, attack-surface management, and continuous monitoring.

Question 2 – Phishing Awareness Simulation Using GoPhish

1. Introduction

Phishing is a social engineering technique in which an attacker attempts to deceive users through fraudulent emails, messages, or websites. Phishing emails may imitate trusted organizations or coworkers to encourage recipients to click links, disclose information, or download malicious files.

GoPhish is an open-source phishing simulation platform that can be used by authorized security teams to assess employee awareness. It provides functionality for managing test recipients, creating email templates, launching campaigns, tracking interactions, and reviewing campaign results.

In this assessment, a controlled simulation is performed using dummy employee accounts supplied in the laboratory. The objective is to evaluate how recipients respond to a simulated phishing message and recommend ways to improve the organization's security awareness.

2. Objectives

- Create a controlled phishing simulation using GoPhish.
- Prepare an educational email template.
- Configure dummy employee recipients.
- Launch the authorized campaign.
- Monitor delivery, opens, clicks, and reporting behavior where available.
- Analyze the campaign results.
- Recommend suitable security awareness and technical controls.

3. Tools Required

Tool	Purpose
GoPhish	Manage phishing simulations
Kali Linux or another authorized lab system	Run the testing environment
Dummy employee accounts	Provide controlled test recipients
Authorized test mail server	Deliver simulation emails
Browser	Access the GoPhish administration interface
Spreadsheet or report editor	Analyze results and document findings

4. Procedure

Step 1: Start GoPhish

Install or start GoPhish according to the official documentation for your environment. Access its administration interface using the address and port configured for your local installation.

Use a local lab environment, protect the administrative interface, and do not expose it publicly without appropriate security controls.

Step 2: Create an email template

Create a simulated email that resembles a routine organizational notification without requesting real credentials or sensitive personal information.

Step 3: Configure the sending profile

Configure an authorized email-sending profile using the test mail service provided for the lab.

Verify that:

- The sender identity is approved for the simulation.
- The receiving accounts are controlled dummy accounts.
- The email service permits the test messages.
- The sending configuration does not affect unrelated users.
- The campaign is clearly bounded by the authorized testing scope.

Step 4: Create a recipient group

Add the dummy employee accounts provided in the lab to a recipient group. Verify the addresses and avoid adding real employees or external recipients without explicit authorization.

Step 5: Configure and launch the campaign

Select the email template, approved sending profile, recipient group, and controlled training destination. Give the campaign a descriptive name, review the settings, and launch it only after confirming that the test is within scope.

Step 6: Monitor campaign interactions

Review the campaign dashboard for available events, such as:

- Emails sent.
- Emails delivered or delivery failures.
- Email opens, if tracking is enabled and supported.
- Link clicks.
- Reports of suspicious messages, if reporting integration is configured.

Record the observed values and the time period covered by the campaign.

Step 7: Export or document the results

Use the reporting or export functionality available in your installed GoPhish version. Include screenshots of the campaign configuration and results, taking care not to expose actual passwords, personal information, or administrative secrets.

5. Important Campaign Metrics

The campaign report should include the following metrics.

Metric	Formula	Meaning
Delivery rate	Delivered emails ÷ Emails sent × 100	Percentage of emails successfully delivered
Open rate	Emails opened ÷ Delivered emails × 100	Percentage of delivered emails recorded as opened

Click rate	Recipients who clicked ÷ Delivered emails × 100	Percentage of delivered recipients who clicked the simulated link
Reporting rate	Recipients who reported the email ÷ Delivered emails × 100	Percentage of delivered recipients who reported the suspicious message

Note: GoPhish versions and tracking configurations may differ in how they record events. Email opens may be undercounted or overcounted because of image blocking, privacy protections, and automated email scanners. Click events can also be affected by automated security systems. Interpret the results with these limitations in mind.

6. Sample Report and Calculation

The following values are hypothetical examples for demonstrating the calculations, not actual results from your GoPhish campaign.Assume that 100 simulation emails were sent, 90 were delivered, 54 were recorded as opened, and 27 recipients clicked the link.

Metric	Calculation	Result
Emails sent	Given	100
Emails delivered	Given	90
Delivery rate	90 ÷ 100 × 100	90%
Recorded opens	Given	54
Open rate	54 ÷ 90 × 100	60%
Unique recipients who clicked	Given	27
Click rate	27 ÷ 90 × 100	30%

Sample campaign results

Delivery rate

90%

Open rate

60%

Click rate

30%

Illustrative figures only. Replace these with the actual results recorded by your lab campaign.

7. Analysis of Campaign Results

A. Delivery rate

The delivery rate indicates how many simulation emails reached the intended recipients. A low rate may indicate incorrect recipient addresses, mail server errors, or email filtering.Recommendation: Verify dummy recipient addresses, inspect delivery failures, and coordinate with the lab's email administrator to ensure that the approved test messages can be delivered.

B. Email open rate

The open rate indicates how many delivered emails were recorded as opened. It provides limited insight into recipient engagement, but it does not prove that a person actually read the message.Recommendation: Use open rates alongside click rates and reporting behavior rather than treating opens as a direct measure of phishing susceptibility.

C. Click rate

The click rate measures how often recipients interact with the simulated link. A high click rate may indicate that recipients do not consistently verify suspicious links or recognize deceptive messages.Recommendation: Provide practical training on URL verification, sender validation, and safe handling of unexpected messages.

D. Reporting rate

The reporting rate helps assess whether employees recognize and report suspicious emails. A higher reporting rate can indicate better awareness, although reporting behavior should be interpreted alongside other evidence.Recommendation: Introduce an easy-to-use email reporting mechanism and acknowledge employees who report suspicious messages promptly.

8. Recommendations to Improve Employee Awareness

1. Conduct regular training: Explain common phishing techniques, suspicious URLs, sender spoofing, and malicious attachments.
2. Repeat controlled simulations: Use different educational scenarios to measure improvement over time.
3. Enable multifactor authentication: Reduce the impact of stolen passwords.
4. Improve email filtering: Configure spam and phishing detection, URL filtering, and attachment scanning.
5. Encourage immediate reporting: Make it simple for employees to report suspicious messages to the security team.
6. Provide immediate feedback: Explain warning signs after a simulation event.
7. Apply role-based training: Give additional guidance to employees who handle payments, confidential records, or administrative accounts.
8. Review campaign results: Compare metrics across campaigns to identify improvement areas.
9. Strengthen incident response: Define procedures for handling suspected credential theft and malware infections.
10. Promote a positive security culture: Encourage learning and prompt reporting rather than discouraging employees from admitting mistakes.

9. Conclusion

GoPhish provides a practical way to evaluate employee awareness through controlled phishing simulations. By measuring delivery, opens, clicks, and reporting behavior, an organization can identify weaknesses and develop targeted training. Combining regular simulations with email security controls, MFA, prompt incident reporting, and continuous evaluation can improve phishing resistance and reduce the risk of social engineering attacks.

Question 3 – Nmap Aggressive Scan and Social Engineering Analysis

1. Introduction

Nmap (Network Mapper) is a network discovery and security auditing tool used to identify active hosts, open ports, running services, and possible operating system details.The Nmap aggressive scan option `-A` enables several detection features, including operating system detection, service/version detection, default script scanning, and traceroute where supported. These features provide more information about the target than a basic port scan.In this assessment, `scanme.nmap.org` is the target specified in the question. The objective is to understand how network reconnaissance information could support a social engineering attack against an IT support team and identify appropriate defensive measures.Authorization note: `scanme.nmap.org` is a public Nmap testing host. Follow the host owner's published scanning rules and keep testing within the permitted scope.

2. Objectives

- Identify open ports and running services.
- Examine available service/version information.
- Review operating system detection results where available.
- Understand how reconnaissance can support social engineering.
- Identify potential organizational risks.
- Recommend appropriate preventive, detective, and corrective security measures.

3. Tools Required

Tool	Purpose
Kali Linux	Ethical hacking environment
Nmap	Network discovery and service identification
Terminal	Execute commands and record output
Text editor	Prepare the assessment report

4. Procedure and Commands

Step 1: Verify Nmap installation

Open the terminal in Kali Linux and execute:

```
nmap --version
```

This command displays the installed Nmap version.

Step 2: Perform the aggressive scan

Execute the following command against the specified test host:

```
nmap -A scanme.nmap.org
```

The command enables several detection features:

- `-A`: Enables OS detection, version detection, default script scanning, and traceroute where supported.
- `scanme.nmap.org`: Specifies the target hostname.

The actual output depends on the host's current configuration, network conditions, and permitted scanning scope.

Step 3: Examine the scan results

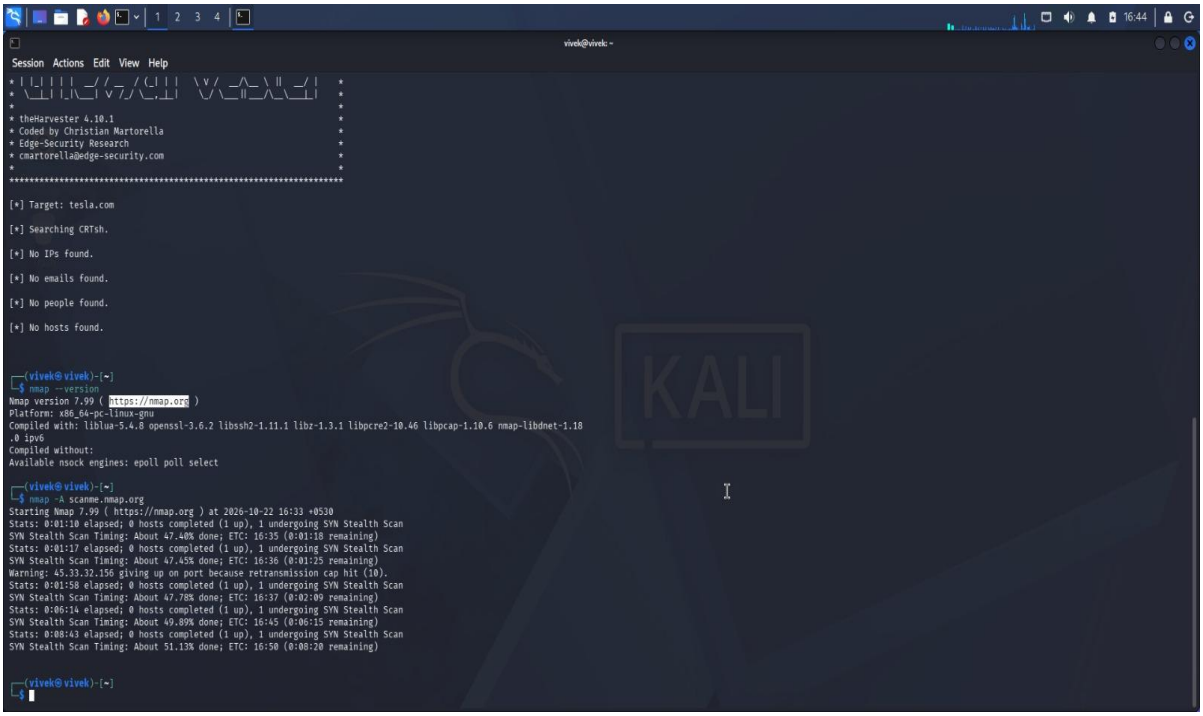
Review the report for the following information:

Finding	Meaning	Security relevance
Open ports	Ports accepting network connections	Identifies exposed services
Service names	Services associated with ports	Reveals available network functions
Service versions	Detected software versions, when identifiable	Helps administrators assess patch status
OS detection	Estimated operating system details	Helps identify potentially outdated platforms
Traceroute	Network path information, if available	May provide limited information about network routing
Script results	Information returned by enabled default scripts	May reveal additional service details

Do not assume that a detected version is vulnerable without verifying the relevant vendor advisories and configuration.

Step 4: Document the results

Record the date, command, target, actual findings, and relevant screenshots. Include only information that was returned by your own authorized scan.The question does not provide actual scan output, so specific open ports, software versions, and operating system details cannot be stated as verified findings here.



5. How Reconnaissance Can Support Social Engineering

Network reconnaissance and social engineering are different activities, but information collected through reconnaissance may help make social engineering more convincing.

A. Identification of technology

Service and operating system details can help security teams understand which technologies are in use. An attacker might misuse such details to create a false technical-support request involving a familiar application or service.

B. Preparation of convincing messages

Knowledge of an organization's technology and IT processes may help an attacker construct a message that appears relevant to the support team.

For example, a fraudulent message might claim that a server requires an urgent security update. The attacker may try to convince an employee to approve an unauthorized change.

C. Impersonation of IT support personnel

An attacker may pretend to be an internal administrator or an external technical service provider. Publicly available organizational information can help the attacker imitate legitimate terminology and workflows.

D. Credential theft attempts

An attacker may attempt to persuade support personnel to disclose credentials or approve a fraudulent authentication request. The risk is greater when employees lack clear identity-verification procedures.

E. Unauthorized change requests

An attacker may attempt to convince an IT employee to modify access permissions, reset an account, install software, or change a configuration without proper authorization.

These examples illustrate potential risks; the Nmap scan itself does not reveal employee credentials or prove that the IT support team is vulnerable.

6. Illustrative Social Engineering Attack Methodology

The following is a high-level attack scenario for defensive analysis, not an instruction to impersonate real personnel.

Step 1: Reconnaissance

Collect permitted public information about exposed services and organizational technology.

Step 2: Identify risk areas

Determine which processes require stronger verification, such as account resets and configuration changes.

Step 3: Attempted manipulation

A hypothetical attacker attempts to exploit trust or urgency to obtain an unauthorized action.

Step 4: Defensive response

Staff verify identity, follow approval procedures, report the request, and security teams investigate suspicious activity.

7. Potential Security Impact

If social engineering succeeds, the organization may experience:

1. Unauthorized access: An attacker may gain access to an account through manipulated account-recovery procedures.
2. Credential compromise: Employees may disclose authentication information or approve fraudulent authentication requests.
3. Service disruption: Unauthorized changes could affect network services or applications.
4. Data exposure: A compromised support account may provide access to information beyond the employee's normal responsibilities.
5. Financial and reputational damage: Security incidents may cause operational costs, loss of trust, and regulatory consequences.

The severity depends on the permissions of the compromised account, the systems accessible to it, and the organization's existing security controls.

8. Defensive Recommendations

A. Strengthen identity verification

Require IT support personnel to verify the identity of individuals requesting password resets, access changes, or sensitive administrative operations. Verification should use approved independent methods rather than relying solely on information supplied in an email or phone call.

B. Apply multifactor authentication

Use MFA for administrative accounts and important systems. Prefer phishing-resistant methods where feasible, particularly for privileged users.

C. Enforce least privilege

Limit support staff permissions according to their responsibilities. Separate routine support activities from high-risk administrative operations.

D. Implement change-management procedures

Require appropriate approval, documentation, and audit trails for sensitive configuration changes, software installations, and privilege modifications.

E. Train IT support personnel

Conduct training on impersonation, pretexting, urgent fraudulent requests, credential theft, and suspicious account-recovery requests.

F. Monitor suspicious activity

Use centralized logging and security monitoring to detect unusual account resets, privilege changes, repeated authentication failures, and unexpected administrative access.

G. Patch exposed services

Review detected service versions, compare them with trusted vendor advisories, and apply necessary security updates. Disable unnecessary services and restrict access to those that must remain available.

H. Maintain an incident response plan

Define procedures for reporting suspected impersonation, disabling compromised accounts, revoking sessions, restoring secure configurations, and investigating potential data exposure.

9. Conclusion

Nmap aggressive scanning can provide valuable information about open ports, running services, software versions, and possible operating system details. Although this information supports legitimate security auditing, it may also assist an attacker in preparing targeted social engineering attempts against IT support personnel.Organizations should combine secure service configuration, timely patching, strong authentication, identity verification, least privilege, employee training, monitoring, and incident response procedures to reduce these risks. Ethical reconnaissance should be conducted only within the authorized scope and should lead to practical security improvements.